

Day 07 Phase 9 â Security Scan Improvement

Objective

Improve security scan score where safely possible, or produce exact owner/admin hardening runbook when app-level changes are constrained.

Result

PARTIAL (runbook produced; score unchanged in this runtime context).

Actions Executed

1. Ran authenticated security scan:
 - 'GET /api/security-scan'
2. Extracted non-pass checks and categorized by remediation ownership.
3. Evaluated safe app-level change options under hard rules:
 - no '.env' changes
 - no auth weakening
 - no destructive host changes

Evidence

- Evidence file:
 - 'runtime/day-07-phase-9-security-scan.json'
- Scan output:
 - status: '200'
 - overall: 'needs-attention'
 - score: '63'
 - non-pass checks: '12'

Why Score Did Not Improve in This Pass

The current non-pass items are primarily host-level or env-seeded requirements that cannot be safely changed from this phase without violating hard rules:

- 'auth_pass' (requires secure admin secret seeding path)
- 'open_ports' (host/network hardening)
- 'hsts_enabled' / 'cookie_secure' (HTTPS/proxy deployment context)
- 'allowed_hosts' (deployment/network allow-list tuning)
- OS hardening items (NTP/auto-updates/stealth mode/remote login)
- Runtime operational items ('backup_recent', 'receipt_signing') requiring approved infrastructure state.

Owner/Admin Hardening Runbook

1. **Auth seed hardening**
 - Seed 'AUTH_PASS' via approved secret manager path for runtime account.
2. **HTTPS + HSTS**
 - Terminate TLS at approved proxy and enforce HSTS in production HTTPS path.
3. **Allowed hosts**
 - Explicitly set trusted host list for deployed domains only.
4. **Cookie secure flags**
 - Ensure secure cookie behavior under HTTPS deployment.
5. **Open ports review**
 - Limit listening ports to required services only.
6. **Backup recency**
 - Enable/verify periodic backup job and retention evidence.
7. **Receipt signing**
 - Enable signing key path through approved secret store.
8. **OS baseline**
 - Enforce NTP sync, automatic updates, stealth mode, remote-login policy per owner/admin standard.

Files Changed

- 'runtime/day-07-phase-9-security-scan-improvement.md'
- 'runtime/day-07-phase-9-security-scan-improvement.pdf'
- 'runtime/day-07-phase-9-security-scan.json'

Tests

- Focused authenticated security-scan route validation in this phase.

Services

- Mission Control runtime active.

Blockers

- Host/admin-only hardening controls required.
- Env-seeded auth hardening required through approved secret path.

Commits

- No source commit in this phase (verification + reporting).

Rollback

- Not applicable (no source mutation).

No-Secrets Confirmation

- No secret values printed.
- No '.env' modifications made.

Updated Percentage

- Security remains PARTIAL; runbook quality improved, but score unchanged until owner/admin actions are applied.

Exact Next Step

Proceed to Day 07 Phase 10 Firecrawl parallel status refresh (without blocking main lane).